

Data Processing Agreement

CHELYS SECURITY

Cover Page · Incorporating Common Paper DPA Standard Terms v1.1

This Cover Page, together with the **Common Paper Data Processing Agreement Standard Terms Version 1.1** (available at commonpaper.com/standards/data-processing-agreement/1.1 and incorporated herein by reference), forms the complete Data Processing Agreement ("DPA") between the parties. The Standard Terms govern all processing of personal data by Provider on behalf of Customer under the Underlying Agreement.

COVER PAGE — KEY TERMS

PROVIDER	Chelys Security, Inc. Utah, United States legal@chelyssecurity.com
CUSTOMER	<i>[Customer legal entity name]</i> <i>[Customer address]</i> <i>[Customer contact email]</i>
UNDERLYING AGREEMENT	Chelys Security Terms of Service, effective May 4, 2026, available at chelyssecurity.com/terms
EFFECTIVE DATE	<i>[Date both parties sign]</i>
GOVERNING LAW	State of Utah, United States
DATA EXPORTER (GDPR)	Customer (controller of personal data subject to GDPR)
DATA IMPORTER (GDPR)	Chelys Security, Inc. (processor acting on Customer's instructions)
PRIVACY CONTACT — PROVIDER	privacy@chelyssecurity.com
PRIVACY CONTACT — CUSTOMER	<i>[Customer DPO or privacy contact email]</i>

1. Subject Matter and Nature of Processing

Provider processes personal data solely to provide the Chelys Security autonomous penetration testing platform ("Service") as described in the Underlying Agreement. Processing includes automated network scanning, vulnerability analysis, AI-assisted report generation, and secure storage of security findings on Customer's behalf.

Provider acts as a **data processor**. Customer acts as the **data controller** and determines the purposes and means of processing. Provider will process personal data only on documented instructions from Customer, including those set out in this DPA and the Underlying Agreement.

2. Categories of Personal Data Processed

The following categories of personal data may be processed in the course of providing the Service:

- **Account data:** Names, email addresses, password hashes, IP addresses, and browser user agents of Customer's authorized users
- **Scan target data:** IP addresses, domain names, hostnames, and network ranges designated by Customer for security testing
- **Vulnerability findings:** Technical vulnerability data, proof-of-concept evidence, CVSS scores, and remediation notes relating to Customer's systems
- **Credentials provided by Customer:** SSH usernames/passwords, web application credentials, cloud API keys, and Active Directory credentials supplied by Customer for credentialed testing
- **Extracted security artifacts:** NTLM password hashes, cracked credential data, and system configuration data discovered during authorized scans
- **Audit log data:** User actions, timestamps, and IP addresses recorded for compliance and abuse-prevention purposes
- **Agent event logs:** Raw tool output, scan commands, and AI reasoning logs generated during scan execution

3. Categories of Data Subjects

- Customer's employees and contractors who use the Chelys Security platform
- Individuals whose data may appear in Customer's systems as discovered during authorized security scans (e.g., usernames, email addresses found in databases or configuration files)

Customer warrants that it has all necessary rights, consents, and lawful bases to submit personal data to Provider for processing under this DPA.

4. Purpose and Duration of Processing

Purpose: To provide the Chelys Security autonomous penetration testing service, including running security scans, generating vulnerability reports, enriching findings with CVE/EPSS data, storing results for Customer review, and enabling remediation tracking.

Duration: Provider will process personal data for the duration of the Underlying Agreement. Upon termination or expiration, Provider will delete or return all personal data within 30 days, except where retention is required by law (see Section 8).

5. Approved Sub-Processors

Customer hereby authorizes Provider to engage the following sub-processors:

SUB-PROCESSOR	LOCATION	PROCESSING ACTIVITY	DATA RECEIVED
Anthropic, PBC (Claude API)	United States	AI-assisted analysis, attack planning, and vulnerability report generation	Scan evidence, raw tool output, vulnerability findings, target hostnames/IPs
Stripe, Inc.	United States	Payment processing and subscription management	Customer email address, billing details (no raw card data stored by Provider)
Amazon Web Services (AWS)	United States	Cloud infrastructure hosting (compute, storage, database)	All data stored or processed by the Service
NIST / NVD API	United States (Federal)	CVE data enrichment	CVE identifiers only (no personal data)
FIRST.org (EPSS API)	International	Exploitation probability scoring	CVE identifiers only (no personal data)

Provider will notify Customer at least 30 days in advance of adding or replacing any sub-processor. Customer may object to a new sub-processor within 14 days of notice. If the parties cannot resolve the objection, Customer may terminate the Underlying Agreement without penalty.

6. Security Measures

Provider implements and maintains the following technical and organizational measures to protect personal data:

- **Encryption in transit:** All data transmitted between Customer and Provider is encrypted using TLS 1.2 or higher
- **Encryption at rest:** All data stored by Provider is encrypted using AES-256
- **Credential encryption:** Sensitive credentials (NTLM hashes, cloud API keys, AD passwords) are encrypted at the field level using AES-256-GCM with keys managed separately from data
- **Access controls:** Role-based access control (Admin / Member / Viewer); multi-factor authentication available for all accounts; JWT-based authentication with refresh token rotation

- **Tenant isolation:** Customer data is logically isolated at the database query level; no Customer can access another Customer's data
- **Audit logging:** All access to and processing of personal data is logged with user identity, IP address, and timestamp
- **Vulnerability management:** Provider conducts regular security assessments of the platform
- **Personnel controls:** Access to production systems limited to authorized personnel on a need-to-know basis

7. Data Subject Rights

Provider will assist Customer in fulfilling data subject rights requests (access, correction, erasure, portability, restriction, objection) to the extent technically feasible, taking into account the nature of the processing. Customer is responsible for receiving and initially assessing data subject requests. Provider will respond to Customer's request for assistance within 15 business days.

8. Data Retention and Deletion

Provider applies the following retention periods to personal data:

- **Vulnerability findings and scan results:** Retained until deleted by Customer, or 1 year after the associated job is deleted, whichever is sooner
- **Customer-provided credentials:** Deleted immediately upon job deletion or account termination
- **Extracted security artifacts (hashes, cracked credentials):** Purged 30 days after job completion
- **Audit log records:** Retained 2 years (required for SOC2 compliance and legal obligations)
- **Billing records:** Retained 7 years (tax law requirement)
- **Account data:** Deleted within 30 days of account termination

Upon written request, Provider will certify in writing the deletion of Customer's personal data within 30 days of receiving the request.

9. Data Breach Notification

Provider will notify Customer without undue delay, and in any event within **72 hours** of becoming aware of a personal data breach affecting Customer's data. Notification will be sent to Customer's Privacy Contact specified in the Cover Page and will include, to the extent known at the time: (a) the nature of the breach; (b) categories and approximate number of data subjects affected; (c) categories and approximate volume of personal data records affected; (d) likely consequences; and (e) measures taken or proposed to address the breach.

10. International Data Transfers

Provider is located in the United States. Where Customer is subject to GDPR or UK GDPR and transfers personal data from the EU/EEA or UK to Provider, the parties agree that such transfers are made pursuant to the Standard Contractual Clauses for the transfer of personal data to third countries (Controller-to-Processor, Module 2), as adopted by the European Commission Decision 2021/914, which are hereby incorporated into this DPA by reference.

For the purposes of the SCCs: (a) Annex I.A is the Cover Page of this DPA; (b) Annex I.B is Section 2 (Categories of Personal Data) and Section 3 (Categories of Data Subjects) of this DPA; (c) Annex II is Section 6 (Security Measures) of this DPA.

11. Audit Rights

Upon Customer's written request, Provider will make available information reasonably necessary to demonstrate compliance with this DPA, including completion of a Provider-approved security questionnaire. Customer may request an audit of Provider's data processing activities no more than once per calendar year, on at least 30 days' written notice, at Customer's expense. Provider may satisfy audit requests through third-party certifications (e.g., SOC2 report) where available.

12. Conflict; Order of Precedence

In the event of a conflict between this DPA and the Underlying Agreement with respect to the processing of personal data, this DPA will control. In the event of a conflict between this DPA's Cover Page and the Common Paper Standard Terms incorporated by reference, this Cover Page will control.

Note: This DPA incorporates by reference the Common Paper Data Processing Agreement Standard Terms v1.1, which can be reviewed in full at commonpaper.com/standards/data-processing-agreement/1.1. The Standard Terms cover additional obligations including confidentiality, cooperation with supervisory authorities, and Provider's general obligations as a processor.

Signatures

By signing below, each party agrees to be bound by this Data Processing Agreement, including the Common Paper DPA Standard Terms v1.1 incorporated herein by reference.

PROVIDER

CUSTOMER

Signature

Signature

Printed Name

Title

Date

Chelys Security, Inc.
Utah, United States

Printed Name

Title

Date

[Customer legal entity name]